

SonarQube ← بنسخته قبل ال Deployment
علشان يعمل Static Code Analysis على ال Source Code
بيكتشف ال Bugs وال Duplicated Code
وكمان بيعيّن جودة الكود ويعدّك ببيّنة Quality Gate
ولو الكود مستوف الشروطين المطلوبين
يساكنها ال Pipeline هتشف ومبتمش ال Deployment

Trivy ← بنسخته علشان يعمل Scan
على ال Docker Images قبل ما نرفعها على ال ECR
أو نعمل Deploy
بيكتشف الثغرات الأمنية الموجودة في ال Images
لسواء في ال OS Packages أو ال Libraries
وبعد ال Scan بيطلع Report فيها :

- * اسم الثغرة
- * مستوى الخطورة
- * اسم ال Package المصاب
- * الإصدار الحالي
- * الإصدار اللّيه فيه الإصلاح لو هتوفر
- * وصف مختصر للتخروج

SonarQube ← بيعتبر جودة وأمان ال Source Code

Trivy ← يفتح أمان Docker Image
وال Dependencies الموجودة بداخلها